

Presentación:

Nombre:
Algelis Severino

Tema:
Introducción y Fundamentos de Redes.

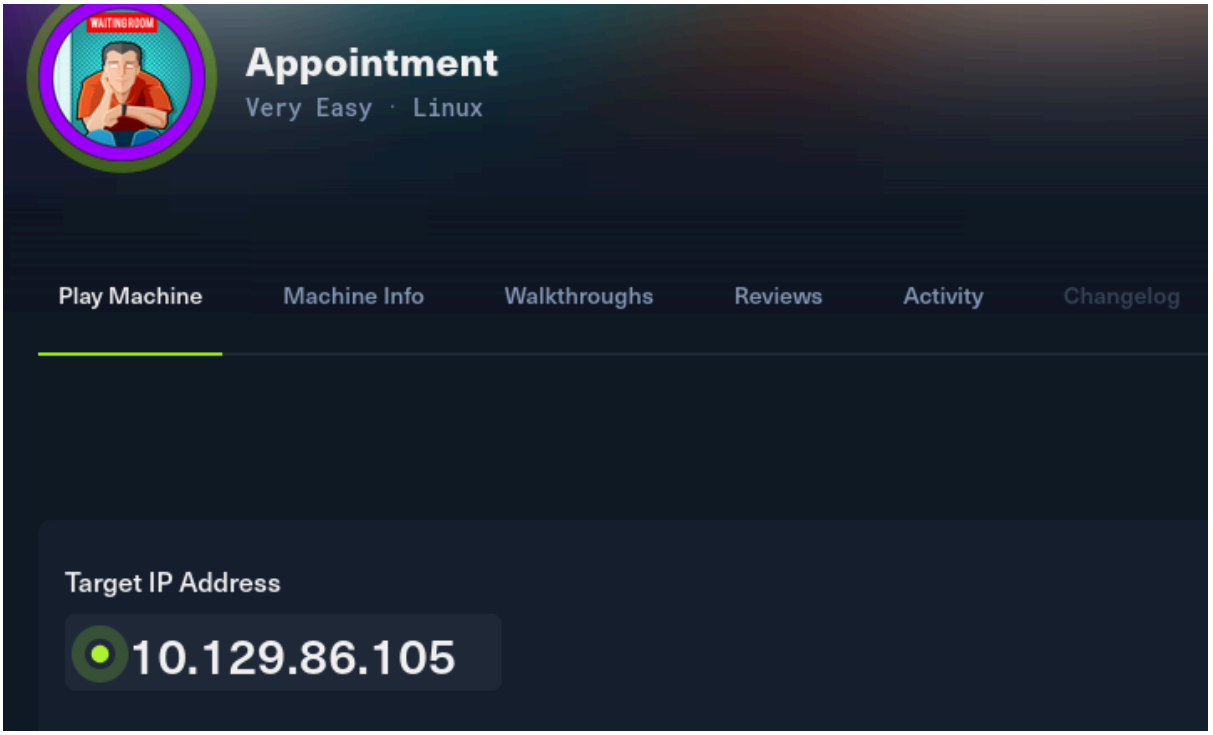
Tecnico:
Ciberseguridad Semipresencial

Facilitador:
Kevin Feliz Henriquez

Centro:
Diapiato Pro salud

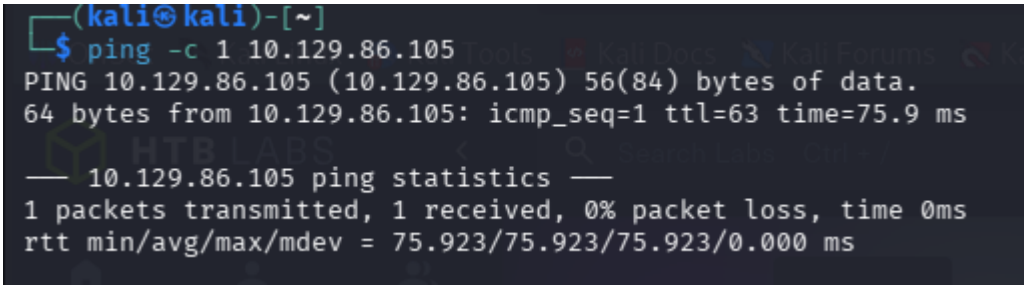
Descripción:
En este documento .pdf esta el paso a paso que seguí para resolver la máquina Appointment según los hallazgos que me dio el escaneo.

Dirección ip maquina victima:



ping -c 1 10.129.86.105:

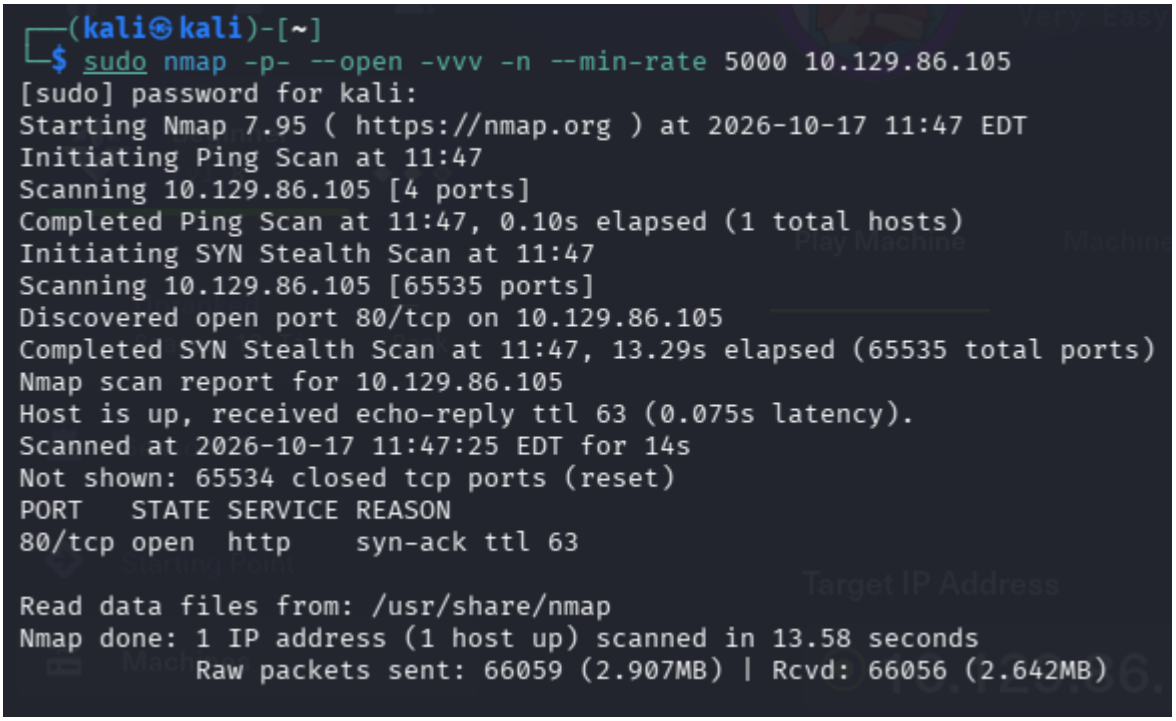
para enviar un paquete y confirmar que la máquina me responde.



Escaneo:

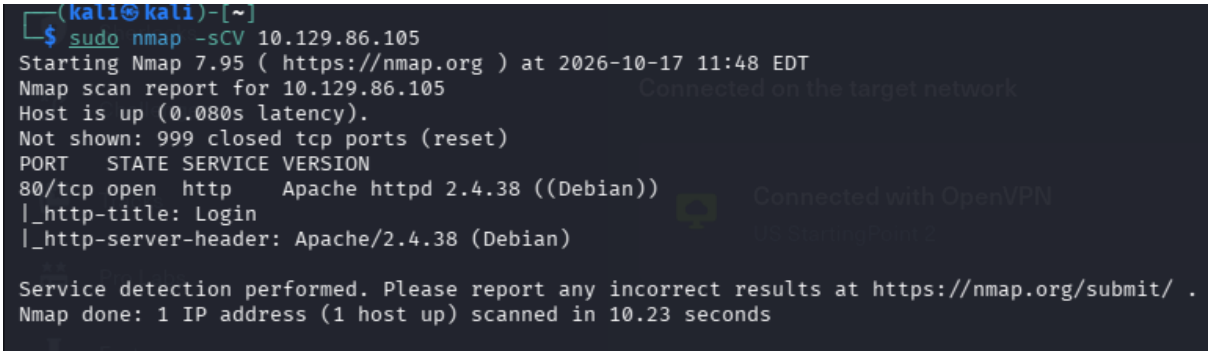
sudo nmap -p- –open -vvv -n –min-rate 5000 10.129.86.105:

sudo nmap: para ejecutar nmap con privilegios elevados.
-p- –open: para indicarle a nmap que escanee todo los puertos y me muestre solo los que están abiertos.
-vvv: para que según vaya encontrando puertos me los vayas mostrando en la pantalla.
-n: para que no me aplique resolución dns.
–min-rate 5000: para indicarle a nmap que envíe 5000 paquetes a la vez y esto le dara mas velocidad al escaneo.

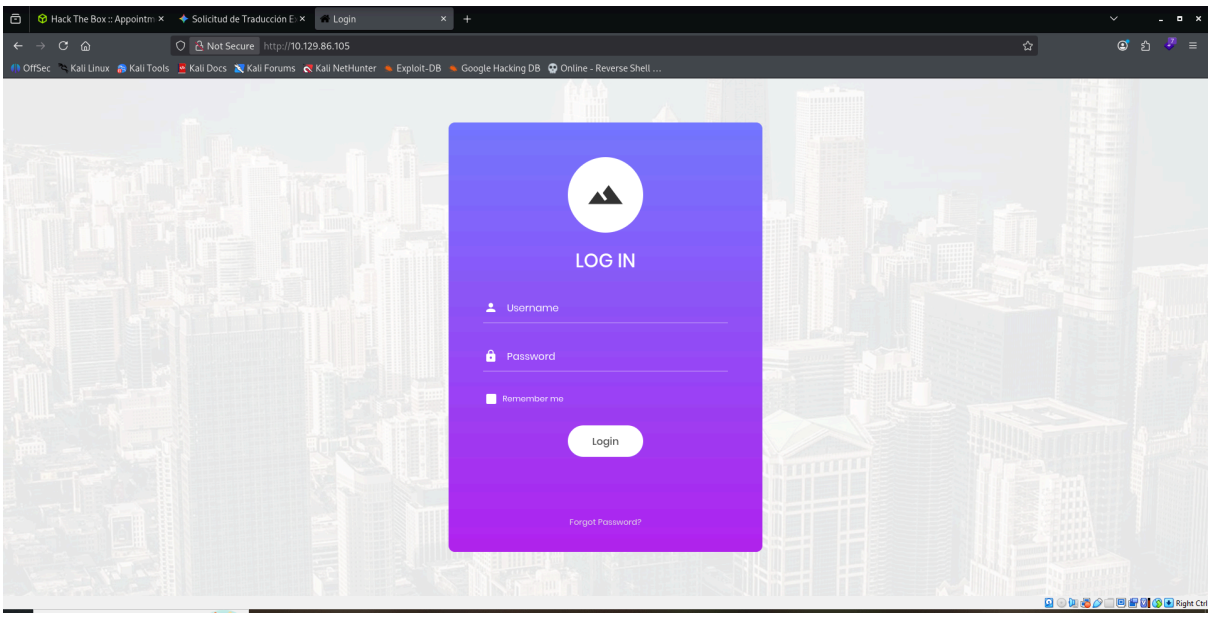


sudo nmap -sCV 10.129.86.105:

para indicarle a nmap que ejecute una serie de script básicos que ya el tiene y me muestre los servicios y las versiones que estan corriendo en la maquina victima.

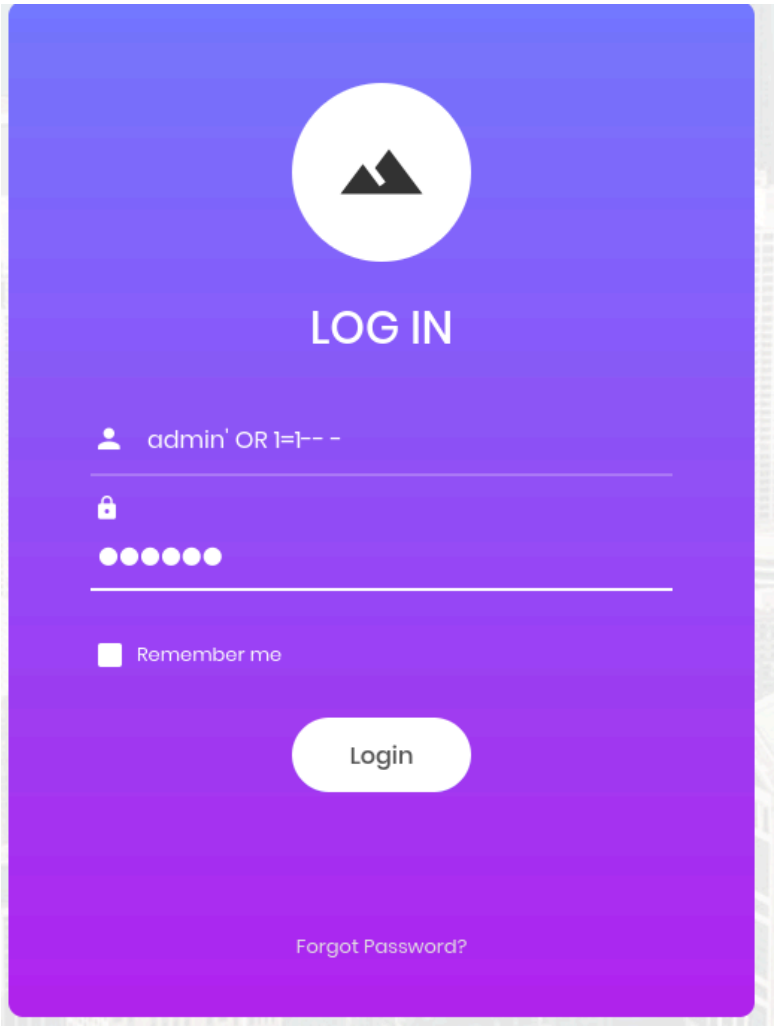


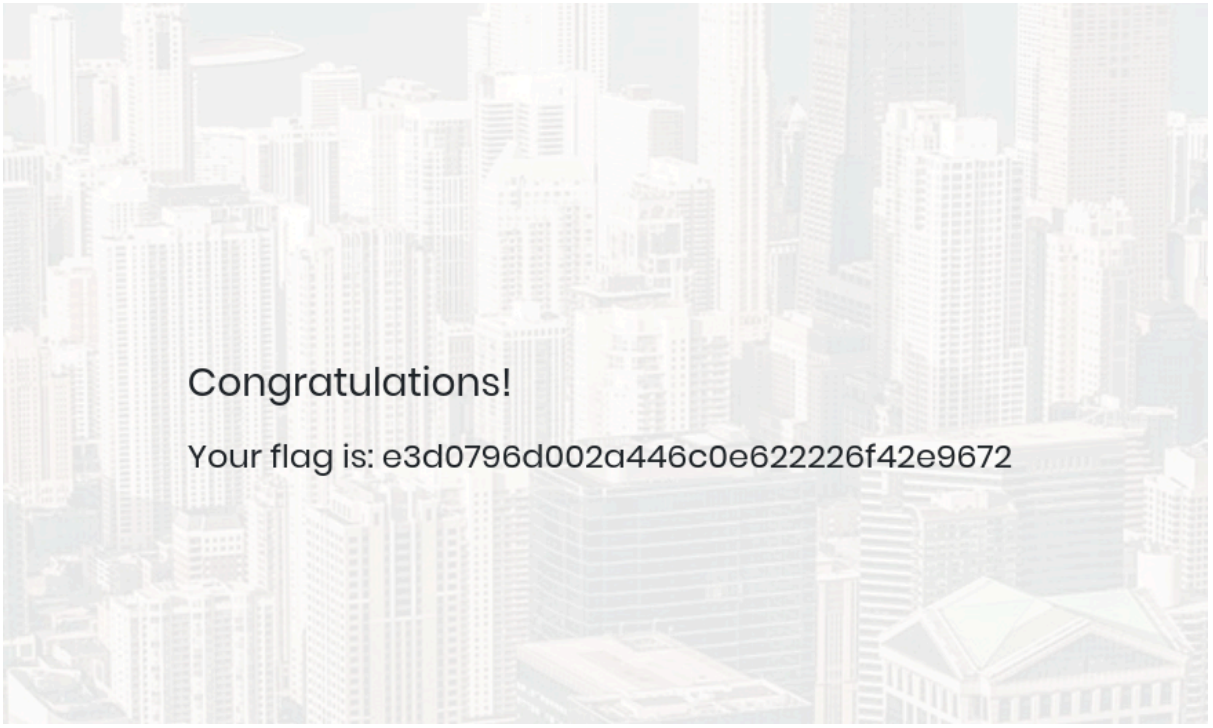
Viendo que tiene el puerto 80 abierto con una pagina web corriendo fui al navegador para ver que tiene la web.



La web tiene un login y voy a probar si este en vulnerable a SQLI (SQL Injection).

admin' OR 1=1– -





y me dio acceso, porque sucede esto?
En el login la consulta se ve asi: select username='admin' and password='miguel', esta consulta me da acceso solo si el user es igual a 'admin' y el password es igual a 'miguel'.

entonces al yo insertar ' OR 1=1 la consulta queda asi:
select username='admin' OR 1=1 and password='miguel', lo que altera completamente la consulta y me da acceso con cualquier password o user que yo ponga, porque la consulta esta usando el operador lógico OR que tiene como condición que al menos 1 de los parámetros sea verdadero entonces 1=1 que es verdadero😎.

Maquina resuelta!

